

Clase 190 — Análisis de logs de Windows: Event Logs y Sysmon

Parte: **8 — Blue Team, detección y SOC** · Fuente: *Blue Team Handbook: SOC, SIEM, and Threat Hunting Use Cases* — Don Murdoch 🕒 Duración estimada: **120 min** · Nivel: **Avanzado**

🎯 Objetivo

Dominar los Event Logs nativos de Windows y Sysmon como fuente central de detección de endpoint. Aprenderás qué Event IDs importan, cómo desplegar y afinar una configuración de Sysmon, y cómo construir detecciones sobre creación de procesos, línea de comandos, conexiones de red, carga de DLLs y manipulación de registro.

📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Identificar** los Event IDs de seguridad más relevantes (4624, 4625, 4688, 4698, 4720...).
2. **Desplegar** y afinar una configuración de Sysmon para detección.
3. **Interpretar** los eventos Sysmon clave (1, 3, 7, 8, 11, 13, 22).
4. **Habilitar** y explotar el logging de PowerShell (ScriptBlock, Module).
5. **Escribir** detecciones sobre estos eventos y mapearlas a ATT&CK.

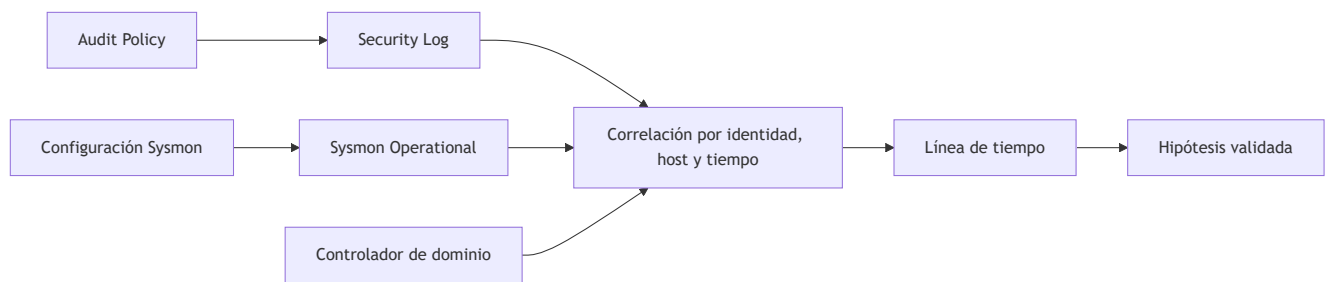
📖 Temas

#	Tema	Por qué importa
1	Canales de Event Log de Windows	Dónde vive cada evento
2	Event IDs de autenticación (4624/4625)	Detectar fuerza bruta y accesos
3	Creación de procesos (4688 vs Sysmon 1)	Ver ejecución y línea de comandos
4	Sysmon: eventos clave y config	Telemetría rica de endpoint
5	PowerShell logging (4103/4104)	Cazar scripts y ofuscación
6	Persistencia (4698, 4657, Sysmon 12/13)	Detectar tareas y cambios de registro
7	Logon types y sesiones	Diferenciar interactivo, red, RDP
8	Afinado y reducción de ruido	Evitar ahogar el SIEM

💡 Explicación en profundidad

Un Event ID de Windows solo tiene significado junto con proveedor, canal, versión y política habilitada. El 4688 depende de auditoría de creación de procesos; Sysmon Event 1 añade hashes y `ProcessGuid`, pero

Sysmon no alerta por sí mismo: registra lo permitido por su configuración.



Un 4624 significa autenticación exitosa, no intrusión. Tipo de logon, cuenta, origen y eventos relacionados determinan si representa consola, red, servicio o sesión remota. La autenticación puede aparecer en el controlador y el proceso en el destino. Las configuraciones comunitarias son puntos de partida: cada inclusión y exclusión debe vincularse a un caso, probar volumen y conservar versión y hash para reproducibilidad.

Interpretar el contexto del evento

Provider y canal delimitan el significado del ID. Un 1 de Sysmon no es el 1 de otro proveedor. En Security, la política efectiva determina si el evento existe y ciertos campos requieren opciones adicionales. Antes de escribir una detección se genera una acción conocida, se observa su XML y se confirma cómo aparecen usuario, equipo y tiempo en esa versión de Windows.

Para RDP, 4624 ofrece un punto de partida, pero se relaciona con tipo de logon, origen, eventos de sesión y actividad posterior. La validación de credenciales puede estar en un controlador de dominio mientras la creación de proceso ocurre en el destino. Se correlaciona por identidad, host y ventana tolerando deriva; no existe un único evento que cuente toda la historia.

4688 y Sysmon Event 1

Ambos describen creación de procesos desde perspectivas diferentes. 4688 pertenece a auditoría nativa y su línea de comandos depende de política; Sysmon 1 puede aportar `ProcessGuid`, hashes y padre según configuración. La ausencia de un campo primero obliga a revisar instrumentación. `ProcessGuid` ayuda a unir Event 1 con conexiones o archivos porque un PID puede reutilizarse.

Sysmon Event 3 conecta proceso y red, pero suele filtrarse por volumen; Event 22 asocia DNS a proceso, sin demostrar conexión posterior. Eventos 11 y 13 aportan archivo y registro. Una correlación explica qué eslabón sustenta cada afirmación: consulta, conexión, escritura o persistencia.

Diseñar la configuración

Incluir todo puede afectar volumen y utilidad; excluir demasiado crea ceguera. Se parte de casos de uso, se mide una muestra y se revisan principales productores. Una exclusión se hace con atributos estrechos y estables, no solo nombre de proceso. Configuración, versión y hash se gestionan como código; después de cambiar se repiten eventos de control. El objetivo no es tener Sysmon instalado, sino saber con precisión qué conducta registra y cuál no.

PowerShell: motor, módulos y bloques de script

PowerShell puede producir varias fuentes según versión y política. Module Logging (por ejemplo, eventos 4103) registra actividad relacionada con módulos; Script Block Logging (4104) registra bloques procesados por el motor y puede fragmentar contenido. Transcription es otra capacidad con implicaciones de almacenamiento y datos sensibles. Habilitar una no implica que todas las demás existan.

La ofuscación puede dificultar lectura, pero el motor necesita interpretar instrucciones; los eventos disponibles dependen de configuración y del modo de ejecución. Se correlacionan host, usuario, runspace/proceso, tiempo y fragmentos. Una palabra sospechosa aislada produce ruido; relación con padre, descarga, AMSI/EDR y red aporta contexto. Los logs pueden contener secretos, por lo que acceso y retención necesitan control.

Persistencia y semántica de cambios

El evento 4698 puede registrar creación de tarea programada cuando la auditoría correspondiente está disponible. Cambios de Registry pueden observarse mediante auditoría nativa o Sysmon 12/13 según configuración. Un cambio en Run key es consistente con persistencia, pero instaladores legítimos lo usan. Se examinan proceso, usuario, ruta, firma y ventana de cambio.

La práctica no memoriza IDs sin fuente: genera tarea y cambio controlados, inspecciona XML y confirma campos. Así puede distinguir «el evento no apareció porque la actividad no ocurrió» de «la política no lo registró».

Glosario

- **Provider:** componente que emite un evento.
- **Channel:** flujo lógico que guarda eventos.
- **Audit Policy:** configuración de categorías auditadas.
- **Event ID:** identificador local al proveedor.
- **Logon type:** clase de sesión autenticada.
- **ProcessGuid:** identificador estable de instancia en Sysmon.
- **Correlación temporal:** unión por entidad y ventana de tiempo.

Definiciones y características

- **Event ID 4624/4625:** logon exitoso/fallido. Característica: incluye *Logon Type* (2 interactivo, 3 red, 10 RDP) clave para el contexto.
- **Event ID 4688:** creación de proceso nativa. Característica: con auditoría de línea de comandos habilitada, registra el CommandLine.
- **Sysmon Event 1 (Process Create):** creación de proceso con hash, línea de comandos, proceso padre. Característica: más rico que 4688 y con integridad de linaje.
- **Sysmon Event 3 (Network Connection):** conexión de red por proceso. Característica: asocia tráfico saliente al binario responsable.
- **Sysmon Event 11/12/13:** creación de archivo y cambios de registro. Característica: detecta persistencia y drops.
- **Sysmon Event 22 (DNS Query):** consulta DNS por proceso. Característica: base para detectar C2/DGA.
- **PowerShell 4104 (ScriptBlock):** registra el bloque de script ejecutado, incluso ofuscado tras des-ofuscar. Característica: visibilidad crítica de ejecución.

Correlación resuelta — RDP y actividad posterior

Se genera una sesión RDP autorizada desde `ADMIN-WS` hacia `SRV-LAB`. En Security se identifica el 4624 con tipo de logon correspondiente y campos de origen disponibles; en el controlador se revisa validación de la cuenta; en Sysmon se observan procesos creados dentro de la ventana. La prueba anota diferencias de reloj.

Luego se repite desde un origen no incluido en el grafo administrativo. La analítica no alerta solo por 4624: combina origen inesperado, cuenta y criticidad, y presenta procesos posteriores. Si la línea de comandos de 4688 está vacía, se comprueba política. Si Sysmon Event 3 está excluido, la clase declara que no puede asociar red mediante esa fuente.

La configuración se cambia para incluir un caso de uso y se mide volumen antes/después. Se guarda XML, hash y versión. Una exclusión comunitaria se revisa línea por línea; que funcione para otro entorno no demuestra que preserve esta detección.

Criterio de dominio

El alumno explica proveedor, canal, ID y política; correlaciona autenticación y proceso sin confundirlos; y demuestra con dos ejecuciones qué registra su configuración. Memorizar una tabla de Event IDs no basta.

Herramientas y preparación

- **Sysmon** con una configuración base robusta (p. ej. la de SwiftOnSecurity o la de Olaf Hartong como punto de partida) adaptada a tu entorno.
- **Directiva de auditoría** de Windows para habilitar 4688 con línea de comandos y logon auditing.
- **Módulo de PowerShell logging** activado por GPO (ScriptBlock y Module Logging).
- Tu SIEM (clases 184/185) recibiendo estos canales vía Winlogbeat/Universal Forwarder.

Practica en tu Windows de laboratorio; nunca en equipos ajenos.

Laboratorio guiado — De evento a detección

1. **Habilita auditoría.** Activa "Audit Process Creation" con inclusión de CommandLine (GPO: *Include command line in process creation events*).
2. **Despliega Sysmon.** `sysmon64.exe -accepteula -i config.xml`. Verifica el canal `Sysmon/Operational`.
3. **Activa PowerShell logging.** Por GPO habilita ScriptBlock (4104) y Module Logging (4103).
4. **Genera actividad.** Ejecuta: un logon fallido repetido (4625), `powershell -enc <base64 benigno>` (4104), y `schtasks /create benigno` (4698).
5. **Detecta autenticación anómala.** En el SIEM, cuenta 4625 por cuenta y `Logon Type`; alerta si hay ráfaga seguida de 4624.
6. **Detecta ejecución sospechosa.** Busca Sysmon Event 1 con `ParentImage` de Office e `Image` de intérprete; correlaciona con Event 3 (conexión) del mismo proceso.
7. **Detecta PowerShell ofuscado.** Sobre 4104, busca indicadores (`FromBase64String`, `-enc`, `IEX`, concatenaciones largas).
8. **Detecta persistencia.** Alerta ante 4698 (tarea) o Sysmon 13 (Run key) creados fuera de la ventana de mantenimiento.

Ejercicios

1. Mapea 8 Event IDs a su técnica ATT&CK correspondiente.
2. Explica los Logon Types 2, 3, 9 y 10 con un caso de uso de detección cada uno.
3. Afinar una config de Sysmon para excluir un proceso ruidoso legítimo.
4. Escribe una detección de "PowerShell descargando y ejecutando" (IEX + Net.WebClient).
5. Diferencia 4688 y Sysmon 1: ¿qué aporta cada uno?
6. Crea una regla para creación de cuenta local sospechosa (4720).

Reto verificable

Entrega tres detecciones basadas en Event Logs/Sysmon (autenticación, ejecución y persistencia) probadas en tu laboratorio, cada una con su Event ID, lógica y técnica ATT&CK. **Criterio de aceptación:** las tres disparan con la actividad que generas y no con la línea base; demuestras que capturas la línea de comandos completa (no truncada) del proceso sospechoso y su relación padre-hijo.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
4688 sin línea de comandos	Falta habilitar "Include command line"; actívalo por GPO
Sysmon genera ruido enorme	Config sin exclusiones; parte de una base afinada y filtra
No aparece PowerShell 4104	ScriptBlock logging desactivado; habilítalo por GPO
CommandLine truncado en SIEM	Límite de campo; ajusta truncation en el forwarder/props
Falsos positivos de tareas	Ventana de mantenimiento no excluida; añade filtro por horario/cuenta

Preguntas frecuentes

¿Sysmon o solo Event Logs nativos? Sysmon puede añadir hashes, identificadores de proceso y telemetría de red/DNS según su configuración. Los eventos nativos aportan autenticación y auditoría que Sysmon no sustituye. Combinarlos amplía el contexto, pero la cobertura final depende de políticas, versiones, configuración y salud de recolección.

¿PowerShell logging captura scripts ofuscados? ScriptBlock (4104) registra el bloque tras des-ofuscar en muchos casos, revelando la intención real. Es una de las fuentes más valiosas contra ataques modernos.

¿Cómo evito que Sysmon sature el SIEM? Parte de una configuración comunitaria afinada, excluye procesos benignos ruidosos y prioriza los eventos con valor de detección (1, 3, 7, 11, 13, 22).

Referencias verificables y alcance

- Microsoft Sysmon: documentación oficial de instalación y configuración; explica que ciertos tipos de evento, como conexiones de red, pueden estar deshabilitados por defecto — <https://learn.microsoft.com/en-us/sysinternals/downloads/sysmon>

- Microsoft, eventos Sysmon: referencia oficial de IDs, campos y semántica; **ProcessGuid** permite correlacionar instancias de proceso — <https://learn.microsoft.com/en-us/windows/security/operating-system-security/sysmon/sysmon-events>
- Microsoft, logging de PowerShell: documentación oficial de los mecanismos y canales de registro de PowerShell en Windows — https://learn.microsoft.com/en-us/powershell/module/microsoft.powershell.core/about/about_logging_windows
- Microsoft, auditoría de seguridad de Windows: documentación oficial para políticas y eventos nativos; la disponibilidad depende de la política aplicada — <https://learn.microsoft.com/en-us/windows/security/threat-protection/auditing/>
- sysmon-modular y sysmon-config: configuraciones comunitarias para estudiar decisiones de inclusión/exclusión; no son baselines universales ni sustituyen pruebas de volumen — <https://github.com/olafhartong/sysmon-modular> · <https://github.com/SwiftOnSecurity/sysmon-config>
- Murdoch, D. *Blue Team Handbook: SOC, SIEM, and Threat Hunting Use Cases*.



Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.



Clase anterior

[Clase 189 — Análisis de endpoints con EDR](#)



Siguiente clase

[Clase 191 — Análisis de logs de red y proxy](#)